

Security Assessment Report

Slush (Sui Wallet) Ecosystem — Web, Browser Extension, Android Application & Related Services

Targets: slush.app web properties · Chrome extension v26.18.0 · Android APK v2 (26.18.0 / code 122)

Assessment type: Authorized external security review (non-destructive)

Date: 24 August 2026

Classification: Confidential — internal use

Table of Contents

1. Executive Summary
 2. Scope, Assets & Methodology
 3. Attack Surface & Endpoint Coverage
 4. Findings Overview
 5. Critical Findings (with reproduced PoCs)
 6. High Findings
 7. Medium Findings
 8. Low / Informational Findings & Positives
 9. Known-Vulnerability (CVE) Correlation
 10. Verification Status & Documented Blockers
 11. Remediation Roadmap
- Appendix A — Full PoC Transcripts
- Appendix B — Evidence Inventory

1. Executive Summary

An authorized external security review of the Slush (Sui Wallet) ecosystem was performed covering the web properties under `slush.app`, the published Chrome extension "Slush — A Sui wallet" (v26.18.0), the Android application (v26.18.0 / versionCode 122, package `com.mystenlabs.suiwallet`), and the related services they depend on (Enoki identity/OAuth, Statsig feature-flag gateway, Stripe on-ramp, OAuth providers, relay/sync API).

Two **CONFIRMED CRITICAL** findings were reproduced live against production infrastructure:

- **C-01 — Production Enoki API key embedded in shipped clients.** A live Enoki API key (`enoki_apikey_be0da54e9cc92700c2be0118a3eccf6a...`) is hardcoded in the Chrome extension and Android application and is **unrotated between versions**. A benign authenticated request using the key returned **HTTP 200** and disclosed the wallet's complete OAuth provider configuration.
- **C-02 — Enoki OAuth origin allow-list is empty.** The wallet's Enoki application is configured with `allowedOrigins: []` and `domains: []`, so **any website origin** may use the wallet's OAuth / zkLogin identity flow. Combined with the disclosed OAuth client IDs (C-01), this is an identity-phishing enabler and an Enoki service/quota abuse path.

One **HIGH** finding is statically confirmed (Android backup/data-extraction gap, H-01). One **HIGH** finding remains **theoretical** (the mobile dApp WebView bridge contains no origin allow-list, H-02) — dynamic confirmation was blocked because the supplied APK is an incomplete App-Bundle base split with no native libraries and cannot run on an emulator or device.

Eight **MEDIUM** findings cover the new Stripe on-ramp deep-link surface, AppsFlyer attribution, over-broad Android permissions, embedded Sentry DSNs, the extension's 24-hour approval window, the relay/sync data layer, a live deployment regression on `my.slush.app`, and server-side payment-verification requirements for the on-ramp.

Positive observations: the live API backend is well-hardened — the GraphQL API is persisted-query-only (introspection and arbitrary queries are rejected), the staging environment is protected

by Vercel deployment protection, the Statsig gateway uses only a public client key (no secret keys present), the browser extension enforces origin-bound authorization for signing, no XSS/RCE sinks were found in the extension, and the embedded dependency set has no applicable disclosed CVEs (including the CryptoJS weak-RNG issue CVE-2026-71851, which does not apply because the wallet uses WebCrypto/noble entropy).

2. Scope, Assets & Methodology

2.1 Authorized scope

Category	Assets
Web	slush.app, www.slush.app, my.slush.app, api.slush.app, initialize.slush.app, staging.slush.app, stellate.slush.app, support.slush.app, assets.slater.app, sui-dev.b-cdn.net, osmo.supply
Browser extension	"Slush — A Sui wallet" (Chrome Web Store id opcgpfmipidbgpenhmajoaajpbobppdil), v26.18.0 (build 1ec36ff)
Android application	APK v2 (26.18.0 / versionCode 122), package com.mystenlabs.suiwallet; plus prior build (v1) from an archived reverse-engineering repository for delta analysis
Third-party services	Enoki (identity/zkLogin/OAuth), Statsig gateway (initialize.slush.app/v1), Stripe Crypto On-ramp, OAuth providers (Apple, Google, Twitch, Facebook), relay/sync API (api.slush.app)
Not in scope / no artifact	iOS application (App Store id6476572140), Halliday on-ramp, Moonpay — no artifacts were available

2.2 Methodology

- **Passive infrastructure enumeration:** DNS records, certificate-transparency authorities, automated subdomain discovery, technology fingerprinting.
- **Non-destructive live probing:** unauthenticated and benign authenticated HTTP probing of all enumerated hosts, HTTP method matrices, webhook/endpoint discovery, GraphQL behavior characterization, API key validation (read-only), TLS assessment.
- **Static analysis of the Chrome extension:** manifest, permissions, content-script bridge, service worker message handling, approval/origin-binding logic, dangerous-sink audit, embedded-credential scan.
- **Static analysis of the Android application:** manifest (permissions, exported components, backup rules), Hermes-bytecode string-table and source extraction of the JS bundle, decompiled Java (native side), embedded-secret scan, deep-link and WebView-bridge logic reconstruction.
- **Dynamic testing attempt:** a KVM-backed Android emulator (Android 11, x86_64) was provisioned; the supplied APK could not run (see Section 10).
- **Vulnerability correlation:** cross-reference of the embedded library inventory against public CVE / advisory databases.

All testing was authorized, non-destructive, and did not modify production data, user accounts, or chain state. No exploitation of user funds or identity flows was attempted.

3. Attack Surface & Endpoint Coverage

3.1 Enumerated infrastructure

Host	Role / Technology	Result
slush.app / www	Marketing site (Webflow), Cloudflare-fronted	200; no app logic
my.slush.app	Previously Vercel app; now serves a Framer marketing page ("Mysten Labs — Shaping the Future of the Internet")	200 (Framer); assetlinks dead (M-07)
api.slush.app	API / relay backend; Cloudflare; UA-based bot protection	403 (default UA), 200 (app UA); only /graphql exists; persisted-query-only
initialize.slush.app/v1	Statsig feature-flag gateway (proxy)	"RBAC: access denied" unauthenticated; works with client SDK key (Section 8)
staging.slush.app	Staging API (Vercel deployment)	401 — Vercel deployment protection (standard)
stellate.slush.app	GraphQL CDN (Stellate), Cloudflare	403/421 — unreachable/misconfigured (dead record)
support.slush.app	Zendesk help center	302; standard SaaS, no exposed API
assets.slater.app	Amazon S3 bucket	404 on all keys; no data leak
sui-dev.b-cdn.net	BunnyCDN (Sui dev assets)	404; no leak
osmo.supply	Redirect to www (unrelated brand)	301; no leak
api.enoki.mystenlabs.com	Enoki identity/OAuth service	Critical findings C-01/C-02 reproduced
api.stripe.com	Stripe API	Publishable key validated — read-only by design

3.2 Coverage statement

All enumerated hosts were probed. Deep static analysis was completed for the extension and both Android builds. The GraphQL API (relay, on-ramp, auth operations) could not be black-box tested because the endpoint is persisted-query-only and the exact query texts could not be reconstructed from the bytecode (Section 10).

4. Findings Overview

ID	Finding	Severity	Status
C-01	Production Enoki API key embedded in shipped clients (extension + Android), unrotated	CRITICAL	CONFIRMED — PoC reproduced

C-02	Enoki OAuth origin allow-list empty (allowedOrigins: [])	CRITICAL	CONFIRMED — PoC reproduced
H-01	Android backup/data-extraction rules leave MMKV/AsyncStorage/Realm exposed	HIGH	CONFIRMED (static)
H-02	Mobile dApp WebView bridge: no origin allow-list; approval origin-binding unverified	HIGH*	THEORETICAL — PoC blocked
M-01	Stripe on-ramp: 5 exported deep-link activities; stripe-connect:// no host restriction	MEDIUM	CONFIRMED (static)
M-02	AppsFlyer + expanded deep-link schemes/hosts (OneLink, sui://, zksend, etc.)	MEDIUM	CONFIRMED (static)
M-03	Over-broad Android permissions (location, microphone, overlay, storage)	MEDIUM	CONFIRMED (static)
M-04	Embedded Sentry DSNs (2 projects) — error-quota abuse / PII in breadcrumbs	MEDIUM	CONFIRMED (static)
M-05	Extension: 24-hour approval expiry per tab+method	MEDIUM	CONFIRMED (code)
M-06	Relay/sync data layer (api.slush.app) — tenant isolation to verify	MEDIUM	CONFIRMED (code)
M-07	my.slush.app serves Framer marketing page; Android assetlinks dead	MEDIUM	CONFIRMED (live probe)
M-08	Stripe on-ramp completion: server-side payment verification must be validated (internal)	MEDIUM	CONFIRMED (flow analysis)

* H-02 carries no severity until dynamically verified (per assessment standard: theoretical findings are not scored).

5. Critical Findings (with reproduced PoCs)

C-01 — Production Enoki API key embedded in shipped clients

Affected	Chrome extension background.js; Android APK v2 JS bundle
Severity	CRITICAL CONFIRMED
Classification	CWE-798 — Use of Hard-coded Credentials

Technical detail

The Enoki client (Mysten identity/OAuth/zkLogin service used by both the extension and the Android app) is instantiated with a hardcoded production API key. The same key is present in the previous build (v1) and the current build (v2) — **it has never been rotated**. The key is present in plaintext in the shipped artifacts.

Reproduced PoC — static extraction

```
$ grep -aoE 'new VD\\(\\{apiKey:"enoki_apikey_[a-f0-9]+' background.js
new VD({apiKey:"enoki_apikey_be0da54e9cc92700c2be0118a3eccf6a
```

Reproduced PoC — key is live (HTTP 200)

```
$ curl -H "x-enoki-api-key: enoki_apikey_be0da54e9cc92700c2be0118a3eccf6a" \
-H "Authorization: Bearer enoki_apikey_be0da54e9cc92700c2be0118a3eccf6a" \
https://api.enoki.mystenlabs.com/v1/app
HTTP 200 (16.8 s)

{"data":{"allowedOrigins":[],"authenticationProviders":[{"providerType":"twitch","clientId":"kwioig7uxb90zsgb08fyziwnahmc1q"},{"providerType":"google","clientId":"768056533295-s37otp56men05m4ppburuo4scl6b5a2.apps.googleusercontent.com"},{"providerType":"twitch","clientId":"uzpfot3uotf7fp9hklsyctn2735bcw"},{"providerType":"google","clientId":"946731352276-pk5glcg8cqo38ndb39h7j093fpsphusu.apps.googleusercontent.com"},{"providerType":"apple","clientId":"com.mystenlabs.suiwallet"},{"providerType":"apple","clientId":"com.mystenlabs.suiwallet.preview"},{"providerType":"apple","clientId":"com.mystenlabs.suiwallet.dev"},{"providerType":"apple","clientId":"com.mystenlabs.suiwallet.web"},{"providerType":"facebook","clientId":"829226485248571"}],"domains":[]}}
```

Impact

- Credential disclosure — the key is valid against production Enoki infrastructure.
- Disclosure of the wallet's complete OAuth provider configuration and client IDs.
- Enoki service abuse (sponsored-transaction budget, quota consumption) and identity-flow abuse (see C-02).

Remediation

1. Rotate/revoke the key immediately and audit Enoki account activity for unauthorized use.
2. Remove credentials from client binaries; proxy Enoki calls through a server-side, scope-restricted key.
3. Treat any value shipped in a client artifact as public.

C-02 — Enoki OAuth origin allow-list is empty

Affected	Enoki application configuration (identity layer used by extension + Android zkLogin/onboarding)
Severity	CRITICAL CONFIRMED
Classification	CWE-284 — Improper Access Control

Technical detail

The Enoki application serving the wallet's OAuth/zkLogin flows returns `allowedOrigins: []` and `domains: []`. The origin allow-list is the primary defense preventing arbitrary websites from using the wallet's OAuth application; with it empty, the guardrail is effectively disabled and **any** origin can leverage the wallet's OAuth app with the disclosed client IDs (C-01).

Reproduced PoC

```
$ curl -s -H "x-enoki-api-key: enoki_apikey_be0da54e9cc92700c2be0118a3eccf6a" \
https://api.enoki.mystenlabs.com/v1/app
{"data":{"allowedOrigins":[],"domains":[],"authenticationProviders":[...]}}
```

The response confirms both `allowedOrigins` and `domains` are empty — no origin restriction is enforced.

Impact

- Any website can initiate the wallet's OAuth/zkLogin identity flow (identity-phishing enabler).
- Abuse of the wallet's OAuth client IDs in phishing campaigns against wallet users.

Remediation

1. Set `allowedOrigins` to the exact trusted host set (web app origin, extension origin, app store schemes).
2. Rotate the key (C-01) regardless, since the configuration is disclosed.

6. High Findings

H-01 — Android backup/data-extraction rules leave wallet storage exposed

Affected	Android APK v1 + v2
Severity	HIGH CONFIRMED (static)
Classification	CWE-921 — Storage of Sensitive Data in a Mechanism without Access Control

Technical detail

`android:allowBackup="true"` is set. The backup/data-extraction rules (`res/xml/secure_store_data_extraction_rules.xml`, `secure_store_backup_rules.xml`) exclude only the SecureStore SharedPreferences domain. The wallet's other storage backends — **MMKV (18 references)**, **AsyncStorage (11)**, **Realm (1)** — are separate storage domains and are **not covered by any exclusion**. They remain included in Auto Backup (cloud), device-to-device transfer, and full backups (`adb backup` on Android < 12). Notably, v2 added exclusions for AppsFlyer analytics data but not for wallet stores.

Reproduced PoC (config evidence from the shipped APK)

```
AndroidManifest.xml:  android:allowBackup="true"
```

```
res/xml/secure_store_data_extraction_rules.xml:
<data-extraction-rules>
  <cloud-backup>
    <include domain="sharedpref" path="." />
    <exclude domain="sharedpref" path="SecureStore" />
  </cloud-backup>
  <device-transfer>
    <include domain="sharedpref" path="." />
    <exclude domain="sharedpref" path="SecureStore" />
  </device-transfer>
</data-extraction-rules>
```

```
Bundle storage backends:  AsyncStorage x11 | MMKV x18 | Realm x1 | SecureStore x5
```

Impact

Wallet state, session/auth tokens, and — if any key material lives outside Keystore-backed SecureStore — key material is extractable from cloud backups or device-to-device transfer. Even on Android 12+ (where `adb backup` of user apps is restricted), cloud backup and D2D transfer remain active while `allowBackup="true"`.

Remediation

1. Exclude the MMKV/Realm/AsyncStorage storage paths in both `data-extraction-rules` and `full-backup-content`, or set `allowBackup="false"`.
2. Confirm at runtime that mnemonic/private keys are exclusively in Keystore-backed SecureStore.

H-02 — Mobile dApp WebView bridge lacks an origin allow-list (THEORETICAL)

Affected	Android app in-app dApp browser (WebView bridge exposing wallet signing)
Severity	HIGH* THEORETICAL — no severity applied
Classification	CWE-346 — Origin Validation Error

Technical detail

The signing-enabled WebView bridge exposes `sui:signTransaction`, `sui:signAndExecuteTransactionBlock`, `sui:signTransactionBlock`, `sui:signPersonalMessage`, `requestPermissions`, `getAccounts` to any page loaded in the in-app browser. A full scan of the Android JS bundle found **zero** occurrences of origin allow-list or origin-validation primitives (`allowedOrigins`, `trustedOrigins`, `validateOrigin`, `verifyOrigin`, `isTrustedOrigin`, `checkOrigin` → all 0 matches). An approval UI and a user-bypassable scam check exist (`bypassedScamWarning` flag), but the approval is not backed by an origin allow-list.

This contrasts with the browser extension, which enforces origin-bound authorization (verified in Section 8). The mobile app's equivalent could not be confirmed due to the artifact issue below.

PoC attempt — blocked (documented)

```
Setup: Android 11 (x86_64) emulator on KVM, rooted image.  
Install: Slush-v2.apk → "Success"  
Launch: com.mystenlabs.suiwallet/.MainActivity
```

```
E AndroidRuntime: com.facebook.soloadery: couldn't find DSO to load: libreactnative.so  
Cause: the supplied APK is an incomplete App-Bundle base split — 0 native libraries  
      (no lib/ directory, no libreactnative.so). It cannot run on any device/emulator  
      and is not a valid standalone install.
```

Required validation (with a complete APK)

1. Re-export a complete universal APK (`bundletool build-apks --mode=universal`).
2. Test whether `my.slush.app/browse?url=<attacker>` (and `sui://` equivalents) loads an arbitrary page into the signing-enabled WebView.
3. Verify the approval screen displays the true requesting origin and binds approval to it.
4. Verify a previously approved origin cannot invoke signing for a different origin.

7. Medium Findings

M-01 — Stripe on-ramp: expanded exported deep-link surface (Android v2)

v2 introduces the Stripe Crypto On-ramp (fiat purchases + KYC) with **five exported BROWSABLE deep-link activities**: `StripeConnectDeepLinkInterceptorActivity` (`stripe-connect://` — **no host restriction**), `FinancialConnectionsSheetRedirectActivity` (`stripe-auth:///stripe://`), `LinkRedirectHandlerActivity` (`link-popup://`), `StripeBrowserProxyReturnActivity` (`stripesdk://`), `FinancialConnectionsSheetLiteRedirectActivity`. Any app or webpage can deliver intents to these activities; the unconstrained `stripe-connect://` scheme is the classic setup for redirect/URL-confusion abuse.

Repro: `adb shell am start -a android.intent.action.VIEW -d "stripe-connect://attacker"` reaches the exported activity. **Fix:** validate all return-URL payloads; keep the Stripe SDK current.

M-02 — AppsFlyer + expanded deep-link schemes/hosts (Android v2)

New in v2: AppsFlyer attribution with the whole-domain deep link `slush.onelink.me` (OneLink links can embed arbitrary paths/params), plus new schemes `sui://`, `exp+sui-wallet://` and new hosts `suiwallet.com/ul`, `my.slush.app/swap`, `zksend.com/claim`. These are additional routes into signing-enabled in-app flows. **Fix:** validate every OneLink/query parameter before routing to transaction/swap/claim flows.

M-03 — Over-broad Android permissions

The app requests `ACCESS_FINE_LOCATION`, `ACCESS_COARSE_LOCATION`, `RECORD_AUDIO` (the iOS Info.plist explicitly states the microphone is unused), `SYSTEM_ALERT_WINDOW` (overlay/interception capability if granted), `READ/WRITE_EXTERNAL_STORAGE` (legacy). A Sui wallet has no legitimate need for precise geolocation or microphone access. **Fix:** remove unjustified permissions; migrate to scoped storage.

M-04 — Embedded Sentry DSNs (2 projects)

Two production Sentry DSNs are embedded (`9bf1491d...@o1314142.ingest.us.sentry.io/4509045450080257`, `o447951.ingest.sentry.io/api/4509632503087104`). Anyone can submit forged events to exhaust the error quota, and breadcrumbs/stack traces may include sensitive wallet data.

Fix: restrict DSNs by `allowedDomains`; scrub PII from breadcrumbs.

M-05 — Extension: 24-hour approval expiry per tab+method

Pending approvals persist with `expiresAt = createdAt + 1e3*60*60*24` (24 h), keyed per tab+method, with dedup (`TOO_MANY_REQUESTS`). A user who approves once leaves a 24-hour window for that tab+method. **Verify:** confirm no silent auto-approve path exists for repeat sign calls within the window; consider shortening the expiry for signing operations.

M-06 — Relay/sync data layer (api.slush.app)

The extension syncs connection/account state through a relay GraphQL layer (`sourceOfTruth: "relay", viewer.dAppConnection.accounts`) served at `api.slush.app`. **Verify:** tenant isolation (one device cannot read another's connection state), and that key material never leaves the device.

M-07 — my.slush.app serves a Framer marketing page; Android assetlinks dead

Reproduced live: `curl https://my.slush.app/` returns the Framer page titled "Mysten Labs — Shaping the Future of the Internet" (previously a Vercel-hosted wallet web app). `/.well-known/assetlinks.json` is unreachable, so Android deep links (`my.slush.app/browse|claim|swap`) likely fail `autoVerify` and degrade to chooser dialogs. **Action:** confirm whether this is an intentional rebrand deployment or a regression; restore assetlinks or update the deep-link host.

M-08 — Stripe on-ramp completion: server-side verification required (internal)

Flow (from APK bytecode): client → backend GraphQL creates an on-ramp session; backend returns `funding_page_onramp_url`, `client_secret`, `client_redirect_url`, `onramp_redirect_url`; client opens the Stripe page; on completion the client calls `completeStripeOnrampSession(session_id)`. The client contains only the public `pk_live` publishable key (validated against the Stripe API: returns `Invalid API Key` on server endpoints — cannot read data or refund). **No `sk_`/`rk_`/`whsec_` keys exist in any client artifact.** The following server-side controls must be verified internally:

1. `completeStripeOnrampSession` must verify the session's real payment status with Stripe (signed webhook or server-side call) — otherwise a client-supplied session ID could complete a never-paid session (free-crypto bug class).
2. Stripe webhook signature (`Stripe-Signature`, `whsec_`) verification on completion events.
3. `referrer_domain/client_redirect_url` allow-listing at session creation (open-redirect/phishing surface).
4. Stripe Link session-end path — same server verification.

8. Low / Informational Findings & Positives

8.1 Low

- **Build metadata exposure:** extension `version_name` "26.18.0 (1ec36ff)" and Sentry release id exposed; aids targeted research on known versions. Source maps are **not** exposed (positive).
- **stellate.slush.app** is unreachable/misconfigured (Cloudflare 403/421) — remove or fix the DNS record.
- **Staging environment** exists publicly (Vercel deployment protection, 401) — standard, but confirm it uses independent secrets.
- **Public Discord invite** and standard third-party SaaS footprint (Zendesk, Webflow, Framer, Cloudflare).

8.2 Positive / hardened controls (verified)

- **Extension origin-bound authorization:** every external RPC is routed through the `dApp` router; signing methods call `getConnectedAccount({origin, accountAddress})`, which requires an approved connection for the requesting origin (else `FORBIDDEN`); approvals capture `originTab.url/appUrl/appName` and are invalidated when the tab navigates away (anti-spoofing); the extension's own origin is excluded.
- **No XSS/RCE sinks:** all 13 `dangerouslySetInnerHTML` occurrences are React/styled-components internals; `eval/Function/innerHTML` uses are library fallbacks or Move-transaction builders.
- **URL-scheme guardrail:** the `dApp` interface blocks `javascript:/data:/blob:/vbscript:` URL schemes.
- **Secure entropy:** `WebCrypto getRandomValues` + noble crypto — `CryptoJS` is not bundled, so **CVE-2026-71851 (weak RNG, "\$5.7M Ill Bloom" wallet drain) does not apply**.
- **API hardening:** `api.slush.app/graphql` is persisted-query-only (introspection and arbitrary queries rejected); `initialize.slush.app/v1` (Statsig) denies unauthenticated access and serves gates with hashed names; only a public Statsig **client** key is present (no secret/conductor keys).
- **Least privilege:** extension requests no `host_permissions`; Android network security uses platform defaults (no cleartext, no user-CA trust); `WebView` debugging is not enabled; only `MainActivity` (plus permission-protected receivers) is exported outside the Stripe set.

9. Known-Vulnerability (CVE) Correlation

Embedded library inventory: `@mysten/sui`, `@mysten/transaction`, `@mysten/serialized-bcs`, `@noble/curves`, `@noble/hashes`, `@noble/ciphers`, `@scure/bip`, `@scure/base`, `jose`, `@wallet-standard/*`, `jspm node polyfills`, `React`, `Hermes runtime`.

CVE / Advisory	Description	Relevance to this assessment
CVE-2023-42374 (9.8)	Sui blockchain node — Move VM compressed-script memory bomb	Not applicable — Rust node component; clients use the TypeScript SDK
CVE-2023-36184 (7.5)	Sui node — stack overflow in /spec/openrpc.json	Not applicable — node component

CVE-2026-71851 (9.0, "III Bloom")	CryptoJS WordArray.random() weak RNG; \$5.7M wallet drain	Not applicable — CryptoJS not bundled; entropy is WebCrypto/noble
CVE-2026-27804 / -22817 / -23552	JWT algorithm-confusion in OAuth adapters	Not directly applicable — no client-side id_token verification; Enoki validates server-side. Equivalent risk path = C-01/C-02
CVE-2022-36083	jose < 4.9.2 PBES2 p2c DoS	Low — jose bundled (32 refs) but the clients do not decrypt attacker-controlled JWEs; confirm jose version is current
@noble/*, @scure/*, @wallet-standard/*, @mysten/*	—	No applicable disclosed CVEs found

Conclusion: the embedded dependency set has no applicable disclosed CVEs for these clients. The actionable critical exposure is not a library CVE — it is the live leaked Enoki credential plus the empty origin allow-list (C-01/C-02).

10. Verification Status & Documented Blockers

Item	Status	Evidence
C-01 Enoki key	CONFIRMED	Static extraction + live HTTP 200 + config disclosure
C-02 allowedOrigins empty	CONFIRMED	Live API response
H-01 backup gap	CONFIRMED (static)	Manifest + extraction rules + storage inventory
H-02 WebView bridge	THEORETICAL	Origin-validation pattern scan (0 hits); dynamic PoC blocked
M-01...M-08	CONFIRMED (static/live)	Manifest/bundle/bytecode/live probes
Stripe server-side verification	UNVERIFIABLE black-box	Persisted-query-only API; server-internal
Relay tenant isolation	UNVERIFIABLE black-box	Server-internal
iOS / Halliday / Moonpay	NOT TESTED	No artifacts available

10.1 Blockers (honest limitations)

- Android dynamic testing:** the supplied APK is an incomplete App-Bundle base split (0 native libraries); it crashes on launch. A complete universal APK is required for the H-02 dynamic test.
- GraphQL black-box testing:** `api.slush.app/graphql` is persisted-query-only; the exact query texts could not be reconstructed from Hermes bytecode (operations are stored as AST fragments with hashes), so the auth/on-ramp/sync operations could not be invoked externally.
- Server-internal controls:** Stripe payment verification/webhook signing and relay tenant isolation cannot be confirmed from client artifacts.

11. Remediation Roadmap

Priority	Action	Ref
P0 — immediate (live today)	Rotate/revoke the Enoki API key; restrict Enoki allowedOrigins to the exact trusted host set; audit Enoki account activity	C-01, C-02
P1 — this release	Extend backup/extraction exclusions to MMKV/Realm/AsyncStorage or set allowBackup="false"; confirm keys live only in Keystore/SecureStore	H-01
P1 — this release	Re-export a complete universal APK; complete the WebView-bridge dynamic test (arbitrary-URL loading, approval-origin display, cross-origin reuse)	H-02
P2 — next release	Internal verification of the 4 Stripe server-side controls; relay tenant isolation audit	M-06, M-08
P2 — next release	Remove unjustified permissions; validate OneLink/deep-link params; restrict Sentry DSNs; shorten extension approval expiry for signing	M-02..M-05
P3 — ops	Resolve the my.slush.app Framer deployment/assetlinks regression; remove/fix the dead stellate record; confirm staging secret isolation	M-01, M-07, LOW
P3 — hygiene	Confirm bundled jse $\geq 4.9.2$; re-run dependency advisories at build time; enforce CI secret scanning	Section 9

Appendix A — Full PoC Transcripts

A.1 Enoki key — static extraction (extension)

```
$ grep -aoE 'new VD\\(\\{apiKey:"enoki_apikey_[a-f0-9]+' ~/.../extension/sui-wallet/background.js
new VD({apiKey:"enoki_apikey_be0da54e9cc92700c2be0118a3eccf6a
# Same key present in Android APK v2 bundle (Hermes bytecode string table)
# and in the v1 build (archived) — never rotated.
```

A.2 Enoki key — live validation

```
$ curl -sS -o /tmp/poc.json -w "HTTP %{http_code} (%{time_total}s)\n" \
-H "x-enoki-api-key: enoki_apikey_be0da54e9cc92700c2be0118a3eccf6a" \
-H "Authorization: Bearer enoki_apikey_be0da54e9cc92700c2be0118a3eccf6a" \
https://api.enoki.mystenlabs.com/v1/app
HTTP 200 (16.77s)
{"data":{"allowedOrigins":[],"authenticationProviders":[ ... twitch/google/apple/
facebook ... ],"domains":[]}}
```

A.3 Backup gap — configuration evidence

```
$ grep -aoE 'android:allowBackup="[^\"]*" AndroidManifest.xml
android:allowBackup="true"

$ cat res/xml/secure_store_data_extraction_rules.xml
<data-extraction-rules>
  <cloud-backup><include domain="sharedpref" path="."/><exclude domain="sharedpref"
path="SecureStore"/></cloud-backup>
  <device-transfer><include domain="sharedpref" path="."/><exclude domain="sharedpref"
path="SecureStore"/></device-transfer>
```

```
</data-extraction-rules>
```

```
$ grep -aoE 'MMKV|AsyncStorage|Realm|SecureStore' index.android.bundle | sort | uniq -c
  11 AsyncStorage
  18 MMKV
   5 SecureStore
```

A.4 WebView bridge — origin allow-list absence (H-02)

```
$ for p in allowedOrigins trustedOrigins validateOrigin verifyOrigin isTrustedOrigin checkOrigin; do
  echo "$p: $(grep -ac "$p" index.android.bundle)"
done
allowedOrigins: 0 | trustedOrigins: 0 | validateOrigin: 0 | verifyOrigin: 0 | isTrustedOrigin: 0 |
checkOrigin: 0

# Bridge methods exposed (bytecode):
"sui:signAndExecuteTransactionBlock" "sui:signTransactionBlock"
"sui:signPersonalMessage" "sui:signAndExecuteTransaction" "sui:signTransaction"
```

A.5 Dynamic test — blocked (incomplete APK)

```
$ unzip -l Slush-v2.apk | grep -cE '\.so$'
0
# Emulator (Android 11, KVM): install OK, launch crashes:
# com.facebook.soloader.y: couldn't find DSO to load: libreactnative.so
```

A.6 Live infrastructure observations

```
$ curl -s https://my.slush.app/ | grep -oE '<title>[^<]+'
<title>Mysten Labs - Shaping the Future of the Internet</title> # Framer page (M-07)

$ curl -s -o /dev/null -w "%{http_code}" https://stellate.slush.app/ # 403 (dead, 421 on SNI)
$ curl -s -o /dev/null -w "%{http_code}" -A "okhttp/5.0.0-alpha.11" https://staging.slush.app/ # 401
Vercel protection
$ curl -s -X POST -H "statsig-api-key: client-F6woN9ItbgXfGHARjqdHwXYtRysCRtGbkffxAkaxfSH" \
  -d '{"user":{"userID":"poc-test"}}' https://initialize.slush.app/v1/initialize
# → feature_gates served (hashed names) — client key is live, read-only by design
$ curl -s -X POST -H "Content-Type: application/json" -d '{"query":{"__typename":""}}' https://
api.slush.app/graphql
# → {"errors":[{"message":"PersistedQueryOnly","extensions":{"code":"CANNOT_SEND_PQ_ID_AND_BODY"}}]}
```

Appendix B — Evidence Inventory

Artifact	Location
Extension package (unpacked CRX v26.18.0)	extension/sui-wallet/ (manifest.json, background.js, dapp-interface.js, content-script.js, offscreen.js)
Android APK v2 (decoded)	apk-v2/decoded/ (AndroidManifest.xml, res/xml, assets/index.android.bundle, smali/, jadx_out/)
Android APK v1 (archived)	src-review/slush-decoded/
Enoki PoC responses	apk-v2/ (poc_enoki.json), reproduced 2026-08-24
Live probe results (hosts, webhooks, Statsig, GraphQL)	web/ (all_hosts.txt, nuclei_web.txt, ffuf_subs.json)

Reports	SUMMARY-REPORT.md, VULNERABILITY-REPORT.md, apk-v2-deep-dive.md, extension-deep-dive-cve.md, src-review-findings.md, report.html
---------	--

Prepared as an independent authorized security assessment. Findings marked CONFIRMED were reproduced or verified with evidence during this engagement; findings marked THEORETICAL carry no severity until dynamically verified. No user funds, accounts, or production data were modified.